

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

Internal ISMS Audit: Simulation Report

AIR-ISMS-AUD-001 | Version 1.0 | June 2026

Document Control

Document ID	AIR-ISMS-AUD-001
Version	1.0
Audit Type	Internal ISMS Audit (Simulated)
Audit Scope	ISO/IEC 27001:2022 — Full ISMS scope (AIR-ISMS-SCO-001)
Audit Period	2–6 June 2026
Report Date	13 June 2026
Classification	Confidential
Lead Auditor	Head of Security & Compliance (independent of operational role for audit purposes)
Technical Support	Head of IT Operations (providing evidence; not auditing their own controls)
Auditee	All departments within ISMS scope
Distribution	Chief Executive Officer Head of Security & Compliance Head of IT Operations Head of Legal & Partnerships

1. Executive Summary

This report presents the findings of AIR's first internal ISMS audit, conducted against ISO/IEC 27001:2022. The audit assessed the establishment and operation of AIR's ISMS across its full scope, covering all four Annex A control themes and ISO/IEC 27001:2022 Clauses 4 through 10.

The audit identified 12 findings in total: 2 major non-conformities, 5 minor non-conformities, and 5 observations. No areas of Annex A were found to be incorrectly excluded from the Statement of Applicability. Several areas of strong conformity were noted, particularly in incident response policy development, asset inventory management, and identity infrastructure.

Finding Type	Count	Certification Impact	Action Required
Major Non-Conformity	2	Must be closed before external certification can proceed	Corrective action plan required within 30 days
Minor Non-Conformity	5	Must be closed within agreed timeframe. Will be verified at next audit	Corrective action plan required within 90 days
Observation / OFI	5	No immediate certification impact. Recommended for improvement	Management response requested; no mandatory deadline
Conformity Noted	8	Controls operating effectively — positive evidence for certification	No action required

OVERALL AUDIT CONCLUSION: AIR's ISMS is at an early but credible stage of development. The policy framework is sound and demonstrates genuine management commitment. The two major non-conformities, relating to supplier security and GDPR record-keeping, are addressable within 60–90 days. Provided these are closed and the five minor non-conformities are on a clear

treatment trajectory, AIR would be in a reasonable position to proceed with an external Stage 1 certification audit in Q4 2026.

2. Audit Scope and Methodology

2.1 Scope

The audit covered AIR's full ISMS scope as defined in AIR-ISMS-SCO-001. The following areas were assessed:

- ISO/IEC 27001:2022 Clauses 4–10 (mandatory ISMS requirements)
- All 93 Annex A controls as documented in AIR-ISMS-SOA-001
- All three office locations: Madrid HQ, Brussels, Riga
- Cloud infrastructure: Azure (air-prod tenant), Microsoft 365, GitHub Enterprise
- On-premises infrastructure: Madrid HQ research data repositories
- Permanent employees (120), contractors (25), and research collaborators

2.2 Methodology

The audit was conducted using a combination of document review, evidence inspection, and interview. The following methods were applied:

Method	Description
Document Review	Review of ISMS policies, procedures, the Risk Register, the Statement of Applicability, the Asset Inventory, and related operational records.
Technical Evidence Inspection	Review of Entra ID configuration, Conditional Access policies, Azure Monitor logs, Intune compliance reports, GitHub Enterprise settings, and Azure Policy assignments.
Interviews	Structured interviews conducted with: Head of IT Operations, Head of Legal & Partnerships, Head of Infrastructure Analytics, one permanent employee, and one contractor.
Sampling	Access rights sampled for 10 employee accounts and 5 contractor accounts. Offboarding records sampled for 5 recent departures. Training records sampled for 15 staff.
Clause-by-Clause Assessment	Each ISO 27001:2022 clause and Annex A control reviewed against the Statement of Applicability and available evidence.

2.3 Finding Classification

Classification	Definition
Major Non-Conformity (NC-M)	A failure to fulfil a requirement of ISO/IEC 27001:2022 that poses a significant risk to the integrity of the ISMS, or the systematic absence of a required control.
Minor Non-Conformity (NC-m)	An isolated failure to fulfil a requirement of ISO/IEC 27001:2022, or a control that is in place but not consistently applied or verified.
Observation / Opportunity for Improvement (OFI)	A situation not constituting a non-conformity but where improvement would strengthen the ISMS or reduce risk.
Conformity (CON)	Evidence that the requirement or control is implemented and operating effectively.

3. Conformities Noted

The following controls and clauses were found to be operating effectively. These represent positive evidence for external certification.

Ref	Control / Clause	Evidence of Conformity
CON-001	5.9 — Asset Inventory	AIR-ISMS-AST-001 is comprehensive, current, and well-structured. Primary and supporting assets clearly linked. Owner assigned to every asset. Annual review scheduled.
CON-002	5.4 — Management Responsibilities	CEO Statement of Commitment present in AIR-ISMS-POL-001. ISMS budget allocated. Quarterly briefings to Executive Leadership confirmed in interview.
CON-003	5.24 — Incident Management Planning	AIR-ISMS-POL-003 approved and distributed. IRT roles defined. Tabletop exercise (AIR-ISMS-EXR-001) planned and scheduled.
CON-004	6.2 / 6.5 / 6.6 — Employment Obligations	Employment contracts and contractor agreements include security responsibilities, post-termination obligations, and NDAs. Confirmed via document review and Legal & Partnerships interview.
CON-005	8.7 — Protection Against Malware	Microsoft Defender for Endpoint deployed across 100% of managed fleet. Defender for Cloud enabled on Azure tenant. Threat alerts routed to Security & Compliance.
CON-006	8.17 — Clock Synchronisation	All Azure and Entra ID services synchronised to Microsoft NTP. Intune policy enforces NTP on managed endpoints. Confirmed via Intune compliance report.
CON-007	5.15 / 8.2 — Access Control and Privileged Access	PIM configured with JIT activation for global admin roles. Max 4 global admins enforced. Break-glass accounts documented with offline credential storage. Azure RBAC partially reviewed.
CON-008	5.12 / 5.13 — Classification and Labelling	Four-tier classification system defined in AIR-ISMS-POL-001. Microsoft Purview sensitivity labels deployed in M365. DLP policies active on Restricted labels.

4. Major Non-Conformities

Major non-conformities must be resolved before AIR can proceed to external certification. A corrective action plan must be submitted to the Lead Auditor within 30 days of this report. Closure will be verified at a follow-up audit.

NC-M-001	ISO/IEC 27001:2022 — 5.19 — Information Security in Supplier Relationships	Risk: High — Restricted data processed by unvetted suppliers
Requirement	ISO/IEC 27001:2022 Control 5.19 requires that processes and procedures are defined and implemented to manage information security risks associated with the use of supplier products and services.	
Observation	No supplier security assessment process has been established. AIR confirmed in interview that no formal security questionnaire exists and that some suppliers with access to Restricted research data (PA-001, PA-002) have never been subject to a security review. Review of three active supplier contracts found that two contained no information security requirements. One legacy contract (dating from 2023) contained only a general confidentiality clause with no specific security controls required. This gap is recorded as RSK-008 in the Risk Register with status 'Open' and no treatment actions started.	
Evidence Reviewed	Supplier contract review (3 contracts sampled). Interview with Head of Legal & Partnerships. Risk Register RSK-008, status: Open, no treatment actions. SoA Control 5.19, status: Not Yet Implemented.	
Required Action	1. Develop and approve a Supplier Security Questionnaire by 31 July 2026. 2. Classify all active suppliers by risk tier and complete assessments for Tier 1 suppliers (those handling Restricted or Confidential data) by 31 August 2026. 3. Add mandatory security clauses to all new supplier contracts immediately. 4. Review and remediate all legacy contracts handling Restricted data by 31 October 2026. 5. Update Risk Register RSK-008 with treatment actions and owner.	
Responsible Owner	Head of Legal & Partnerships	
Target Date	31 August 2026 (Tier 1 assessment completion)	

NC-M-002	ISO/IEC 27001:2022 — 5.34 — Privacy and Protection of PII / Clause 6.1.2	Risk: High — Active GDPR non-compliance; regulatory enforcement risk
Requirement	ISO/IEC 27001:2022 Control 5.34 requires that privacy and protection of PII is identified and met in accordance with applicable laws and regulations. GDPR Article 30 requires a Record of Processing Activities (ROPA) to be maintained for all personal data processing.	
Observation	AIR has not completed a Record of Processing Activities. Interview with the Head of Legal & Partnerships confirmed that a ROPA was started in early 2025 but was never completed or approved. The incomplete draft covers only employment records and omits: research participant data processed in PA-001 and PA-002, contractor personal data, and data processed via Microsoft 365 and GitHub Enterprise. No Data Protection Impact Assessment (DPIA) has been completed for any processing activity. This represents a direct breach of GDPR Article 30 obligations and was also identified as RSK-013 in the Risk Register.	
Evidence Reviewed	Incomplete ROPA draft (reviewed, covers employment records only). Interview with Head of Legal & Partnerships. Review of PA-001 and PA-002 metadata, personal data confirmed present. Risk Register RSK-013, status: Open.	
Required Action	1. Complete ROPA to cover all processing activities by 31 July 2026. 2. Conduct DPIA for PA-001 and PA-002 data processing by 31 August 2026. 3. Conduct DPIA for HR and contractor data processing systems by 31 October 2026. 4. Assign a Data Protection Lead responsible for GDPR ongoing compliance. 5. Update Risk Register RSK-013 with treatment actions and revised target date.	
Responsible Owner	Head of Legal & Partnerships	
Target Date	31 July 2026 (ROPA completion)	

5. Minor Non-Conformities

Minor non-conformities must have a corrective action plan in place within 90 days of this report. Closure will be verified at the next scheduled internal audit or at the external Stage 2 audit, whichever comes first.

NC-m-001	ISO/IEC 27001:2022 — 5.17 — Authentication Information 8.5 — Secure Authentication	Risk: Medium — Partial MFA bypass exposure
Requirement	Controls 5.17 and 8.5 require that authentication is managed securely and that secure authentication technologies are implemented consistently. The Access Control Policy (AIR-ISMS-POL-002) mandates MFA for all accounts with no exceptions and prohibits SMS-based MFA.	
Observation	Entra ID MFA coverage report reviewed, 96.8% of active accounts have MFA registered. Five accounts (4 employees, 1 contractor) have MFA registered as SMS one-time code only, a method prohibited by AIR-ISMS-POL-002 Section 5.1. Additionally, one legacy application account does not have MFA enforced due to a Conditional Access exclusion applied in March 2026. No documented justification or approval was found for this exclusion. The exclusion was confirmed by IT Operations as a temporary workaround that was never reviewed.	
Evidence Reviewed	Entra ID MFA registration report (reviewed June 2026). Conditional Access policy configuration review, exclusion group identified. AIR-ISMS-POL-002 Section 5.1, SMS prohibited; no exceptions permitted.	
Required Action	1. Migrate the 5 SMS-only accounts to Microsoft Authenticator by 31 July 2026. 2. Remove the Conditional Access exclusion or document and approve a formal exception with a time limit and compensating control by 15 July 2026. 3. Implement a monthly MFA coverage report delivered to Head of Security & Compliance. 4. Add MFA method enforcement to the Conditional Access policy configuration.	
Responsible Owner	Head of IT Operations	
Target Date	31 July 2026	

NC-m-002	ISO/IEC 27001:2022 — 5.16 — Identity Management 5.18 — Access Rights	Risk: High — Active stale account; direct link to RSK-005
Requirement	Controls 5.16 and 5.18 require that the full lifecycle of identities is managed, including timely deprovisioning. AIR-ISMS-POL-002 Section 4.3 mandates account disable within 2 hours of last working day and full deprovisioning within 24 hours.	
Observation	Offboarding records for 5 recent departures were sampled. Findings: 2 of 5 accounts were disabled within the required 2-hour window. 1 account was disabled 3 days after the departure date with no documented explanation. 1 account (a contractor) was still active at the time of audit, the contractor departed 11 days ago. IT Operations confirmed the HR notification email was received but not actioned due to workload. This finding is consistent with RSK-005 (Incomplete Offboarding), a known high-risk item, and with the root cause demonstrated in the tabletop exercise (AIR-ISMS-EXR-001).	
Evidence Reviewed	Offboarding records: 5 sampled (2 compliant, 2 non-compliant, 1 outstanding). Entra ID sign-in logs: contractor account confirmed active at audit date. IT Operations interview. Risk Register RSK-005, status: Open.	
Required Action	1. Immediately disable the active contractor account identified during audit. 2. Implement automated Entra ID account deprovisioning via HR system integration by 30 September 2026. 3. Until automation is in place: implement a daily IT Operations check of pending offboarding notifications. 4. Conduct a full audit of all contractor accounts against current HR records by 31 July 2026. Update Risk Register RSK-005.	
Responsible Owner	Head of IT Operations	
Target Date	30 September 2026 (automation); immediate (stale account)	

NC-m-003	ISO/IEC 27001:2022 — 5.18 — Access Rights	Risk: Medium — Accumulated inappropriate access rights
Requirement	Control 5.18 requires that access rights are reviewed at defined intervals. AIR-ISMS-POL-002 Section 9 mandates an annual access review for all employee accounts and a quarterly review for contractor accounts.	
Observation	No annual employee access review has been conducted. The ISMS has been operational since January 2026, the first annual review is overdue. The first quarterly contractor access review (due February 2026) was not completed. The May 2026 quarterly review is in progress but not yet closed. Access review results are not being recorded in a way that produces auditable evidence. IT Operations confirmed reviews are discussed informally with department heads but no formal approval or sign-off is documented.	
Evidence Reviewed	AIR-ISMS-POL-002 Section 9, review schedule defined. IT Operations interview, no formal review completed. No access review records or sign-off documents found.	
Required Action	1. Complete the in-progress May 2026 contractor access review with formal Asset Owner sign-off documentation by 30 June 2026. 2. Conduct the first annual employee access review by 31 August 2026. 3. Develop a standardised access review template with required sign-off fields. 4. Schedule the next quarterly contractor review (August 2026) in the security calendar.	
Responsible Owner	Head of IT Operations	
Target Date	31 August 2026	

NC-m-004	ISO/IEC 27001:2022 — 6.3 — Information Security Awareness, Education and Training	Risk: Medium — Policy awareness gap across organisation
Requirement	Control 6.3 requires that personnel receive appropriate security awareness education and training, and that this is updated regularly. AIR-ISMS-POL-001 Section 3 states a 100% training completion target and requires completion within 30 days of joining and annually thereafter.	

Observation	Training records for 15 staff sampled. Findings: 9 of 15 had received a security briefing at onboarding. 6 of 15 had no training record. No structured annual training programme exists. The onboarding security briefing is delivered informally. No consistent content, no assessment, no completion record. Three contractors (of 25 total) confirmed in interview they had received no security briefing. No training completion tracking system is in place. Staff were unable to locate the Incident Response Policy when asked during interview.
Evidence Reviewed	Training records sampled: 15 records (9 with any record, 6 with none). Interviews with 1 employee and 1 contractor. AIR-ISMS-POL-001: 100% completion target stated. SoA Control 6.3, status: Partially Implemented.
Required Action	1. Define a minimum security awareness training content set by 31 July 2026. 2. Deliver training to all employees and contractors with no current training record by 31 August 2026. 3. Implement a training completion tracking mechanism (e.g. Microsoft Viva Learning or equivalent) by 30 September 2026. 4. Establish an annual training cycle with completion deadlines and reporting to Head of Security & Compliance.
Responsible Owner	Head of Security & Compliance
Target Date	31 August 2026

NC-m-005	ISO/IEC 27001:2022 — 8.15 — Logging 8.16 — Monitoring Activities	Risk: High — Delayed detection; incomplete audit trail
Requirement	Controls 8.15 and 8.16 require that logs are produced, stored and protected, and that systems are monitored for anomalous behaviour. AIR-ISMS-RSK-002 identifies this as RSK-006, a High-rated risk.	
Observation	Azure Monitor and Log Analytics Workspace are in place. However: 3 of 12 in-scope systems (including the on-premises research repositories SA-008) do not forward logs to the central workspace. Alert rules are not tuned to AIR-specific threat scenarios, only default Microsoft alerts are active. During the tabletop exercise, an alert sat unread for 23 minutes in a shared inbox, no escalation or acknowledgement process exists. Log retention is set to 31 days on two log sources; AIR-ISMS-POL-003 requires a minimum of 90 days.	
Evidence Reviewed	Azure Monitor log source inventory review: 3 sources missing. Log Analytics retention settings: 2 sources at 31-day retention. Alert configuration review: default rules only, no custom rules. Tabletop exercise AIR-ISMS-EXR-001: 23-minute alert response gap. Risk Register RSK-006, status: Open.	
Required Action	1. Connect SA-008 and remaining missing log sources to Log Analytics Workspace by 31 August 2026. 2. Set all log sources to minimum 90-day retention by 31 July 2026. 3. Define and implement detection alert rules for high-priority scenarios (credential theft, bulk download, after-hours access) by 30 September 2026. 4. Implement an alert acknowledgement process with escalation if unacknowledged within 30 minutes.	
Responsible Owner	Head of IT Operations	
Target Date	30 September 2026	

6. Observations / Opportunities for Improvement

Observations are not non-conformities. They do not require corrective action plans but represent areas where improvement would reduce risk or strengthen the ISMS. Management is invited to respond to each observation.

OFI-001 — 5.7 — Threat Intelligence

No formal threat intelligence capability is in place. AIR's exposure to nation-state actors targeting critical infrastructure research is a credible and documented risk, yet no structured threat feed or sector ISAC membership exists. Recommend: identify and join a relevant information sharing and

analysis centre (e.g. energy or transport sector ISAC) and establish a quarterly threat briefing process.

OFI-002 — 8.23 — Web Filtering

No dedicated web filtering solution is deployed. Microsoft Defender SmartScreen provides basic protection on managed endpoints but is not enforced via Intune policy and provides no centralised visibility. Given that phishing is a primary attack vector for AIR, web filtering would provide meaningful defence-in-depth. Recommend: evaluate Microsoft Defender for Endpoint web content filtering or equivalent.

OFI-003 — 8.33 — Test Information

Real Restricted research data from PA-001 and PA-002 is used in development and test environments. This is a concern under GDPR and increases the attack surface for research data. Recommend: develop a test data management procedure and implement data masking or synthetic data generation for test environments by end of 2026.

OFI-004 — 8.29 / 8.34 — Security Testing and Audit Testing

No penetration test has been conducted and none is yet scheduled. For an organisation handling government-affiliated Restricted data, an annual penetration test is strongly recommended and may be required by government partner agreements. Recommend: commission an external penetration test of AIR's Azure environment and key web-facing applications in H2 2026.

OFI-005 — 7.10 — Storage Media

No removable media policy exists and USB storage is not restricted via Intune. While removable media is not a primary risk for AIR's cloud-first environment, it represents a straightforward data exfiltration vector, particularly relevant given the insider IP exfiltration risk (RSK-007).

Recommend: implement USB storage restriction via Intune device configuration and define a removable media policy within the Acceptable Use Policy.

7. Conclusions and Recommendations

AIR's ISMS is in an early but credible state. The organisation has demonstrated genuine commitment from Executive Leadership, a well-structured asset inventory, an approved policy framework, and a realistic risk register. These are strong foundations for certification.

The two major non-conformities are addressable within the proposed timeframes and do not indicate systemic ISMS failure. They reflect gaps that are common in first-year ISMS implementations: supplier management and GDPR record-keeping are frequently underestimated in scope until an audit brings them into focus.

The five minor non-conformities connect to three themes: access lifecycle management, people controls (training and awareness), and technical monitoring. A stronger training programme and more consistent access review process would close three of the five minor findings simultaneously.

Priority Recommendations for Management

Immediate (within 30 days): Disable the active stale contractor account (NC-m-002). Begin ROPA completion (NC-M-002). Submit corrective action plans for NC-M-001 and NC-M-002.

Short-term (by 31 August 2026): Complete MFA remediation (NC-m-001). Complete ROPA and commence DPIAs (NC-M-002). Conduct first employee access review (NC-m-003). Deliver catch-up security training (NC-m-004).

Medium-term (by 31 October 2026): Implement automated offboarding deprovisioning (NC-m-002, RSK-005). Deploy Tier 1 supplier assessments (NC-M-001). Extend log coverage and tune alert rules (NC-m-005). Commission external penetration test (OFI-004).

Pre-certification (Q4 2027): Conduct a follow-up internal audit to verify closure of all major and minor NCRs. Submit Stage 1 external audit application if all major NCRs are closed and minor NCRs are on a documented, tracked treatment trajectory.

8. Auditor Declaration

This audit was conducted in accordance with AIR's internal audit procedure and ISO/IEC 27001:2022 requirements for internal audit (Clause 9.2). The findings represent the auditor's professional assessment based on the evidence reviewed during the audit period. Where evidence was unavailable or withheld, this has been noted in the relevant finding.

This report is based on a point-in-time assessment. Controls not reviewed during this audit should not be assumed to be conformant.

Role	Name	Signature	Date
Lead Auditor	Head of Security & Compliance		June 2025
ISMS Management Representative	Chief Executive Officer		June 2025